



FOR JAVA DEVELOPERS MOVING TO NESTJS

New route. Wide open.

Spring Boot to NestJS, episode 20: authentication and guards

Spring Boot secures every route by default. A Nest guard secures what you bind it to. Bind authentication globally and mark the exceptions public.

A refunds route added beside a guarded payments controller, with no security code of its own: Spring Boot answered 401, NestJS answered 200.

APP_GUARD with a @Public() marker made every route private by default: 401, 401, and a public health check 200.

@PreAuthorize did nothing until @EnableMethodSecurity. A Nest role guard stops at the route: the service called directly still ran.

In scope

- SecurityFilterChain against guards
- APP_GUARD and a @Public() marker
- 401 against 403
- @PreAuthorize against @Roles with a RolesGuard

Not in scope

- JWT and Passport strategies
- Sessions and OAuth

The probe tokens and role headers are stand-ins; the scoping is the point.

01 The measurements

SPRING, STARTER ONLY: /payments, /refunds	401, 401
NEST, @UseGuards ON PAYMENTS: /payments, /refunds	403, 200
NEST, APP_GUARD + @Public(): /payments, /refunds, /health	401, 401, 200
NEST, WRONG TOKEN / SPRING, WRONG PASSWORD	403 / 401
SPRING @PreAuthorize, NO @EnableMethodSecurity	user 200; direct call ran
SPRING @PreAuthorize, WITH @EnableMethodSecurity	user 403; direct call refused
NEST @Roles + RolesGuard	user 403, admin 200; direct call ran

Anonymous unless stated.

02 Make authentication global

Register the guard as APP_GUARD so it runs on every route, and let open routes say so with metadata the guard reads through the Reflector. Throw UnauthorizedException for missing credentials; returning false gives 403.

global.spec.ts, the guard

```
canActivate(context: ExecutionContext): boolean {
  const open = this.reflector.getAllAndOverride<boolean>(IS_PUBLIC, [context.getHandler(),
context.getClass()]);
  if (open) return true;
  const req = context.switchToHttp().getRequest<{ headers: Record<string, string | undefined>
}>();
  if (!req.headers.authorization) throw new UnauthorizedException();
  return req.headers.authorization === 'Bearer valid';
}
```

global.spec.ts, registration and the marker

```
const IS_PUBLIC = 'isPublic';
const Public = () => SetMetadata(IS_PUBLIC, true);
providers: [{ provide: APP_GUARD, useClass: GlobalTokenGuard }],
```

APP_GUARD: /payments 401, /refunds 401, /health (public) 200

Run on a real machine, 2026-09-30, by scripts/verify-guards.sh in the course repository.

03 Method authorization

Spring Boot's security starter does not switch method security on. A Nest guard runs for a route, so a service called from elsewhere is not checked.

```
RefundService.java
```

```
@PreAuthorize("hasRole('ADMIN')")
public String approve() {
    return "approved";
}
```

```
MethodSecurityConfig.java
```

```
@Configuration
@EnableMethodSecurity
class MethodSecurityConfig {
}
```

without `@EnableMethodSecurity` a USER got 200; with it, 403 and a direct call threw `AuthenticationCredentialsNotFoundException`

Run on a real machine, 2026-09-30, by `scripts/verify-guards.sh` in the course repository.

Before you trust a NestJS API's security

1. Is authentication registered globally, or bound per controller?
2. Is every open route marked public on purpose?
3. Missing credentials: 401. Known but not allowed: 403.
4. In Spring, is `@EnableMethodSecurity` on where `@PreAuthorize` is used?
5. Does anything call a protected service without going through a route?
6. Add a test that a brand new route is refused



Everything else

- | | |
|--|---|
|  Site
https://code-with-sam-dev.github.io |  Facebook
https://www.facebook.com/codewithsamdev |
|  YouTube
https://www.youtube.com/@CodewithSam-Dev |  GitHub
https://github.com/code-with-sam-dev |
|  LinkedIn
https://www.linkedin.com/company/code-with-sam-dev |  Buy me a coffee
https://buymeacoffee.com/codewithsam |
|  x
https://x.com/CodeWithSamDev |  Buy me sadza
https://buymesadza.com/codewithsam |
|  TikTok
https://www.tiktok.com/@codewithsamdev | Every measurement, one command: scripts/verify-guards.sh
https://github.com/code-with-sam-dev/spring-to-node |
|  Instagram
https://www.instagram.com/codewithsamdev | NestJS guards
https://docs.nestjs.com/guards |

If this was useful, a like and a subscribe help more than you would think. And tell me in the comments which part of your workflow you want taken apart next.

Spring is a trademark of Broadcom. Java is a trademark of Oracle. Node.js is a trademark of the OpenJS Foundation. This is an independent, unofficial guide produced by Code with Sam, not affiliated with or endorsed by any of them.

Technical claims verified 2026-09-30 against the documentation named beside each one. Vendors change behaviour and defaults between versions, so check the version you are actually running before you rely on any of it.